



Securing AI starts with **Identity**



Dean Clarke
Regional Vice President, Sales (APJ)
Agentic Technology Specialists | SailPoint

M: +61 420 465 293
E: dean.clarke@sailpoint.com



Investment in AI will continue to rise...

Global AI Investment

\$3T

2027 Projected AI Spending.

(Source: [Gartner](#))

South Korea Chips, AI, DC Investment

\$800B

1.3T KRW

"Three Mega Project" by 2035.

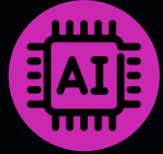
(Source: [MLQ.AI](#))

80%

of enterprise software and applications will be multimodal by 2030.

(Source: [Gartner](#))

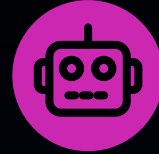
which is impacting every Organization today..



AI agent Adoption

91% of organizations have deployed AI agents.

97% of AI agents have access to sensitive data.



NHI Explosion

AI agents rely on **NHIs** for access.

NHI's now outnumber Humans by **144:1**.



Expanding Attack Surface

87% of companies had an API attack in 2025.

2,383 cyber breach incidents in 2025 – SK.

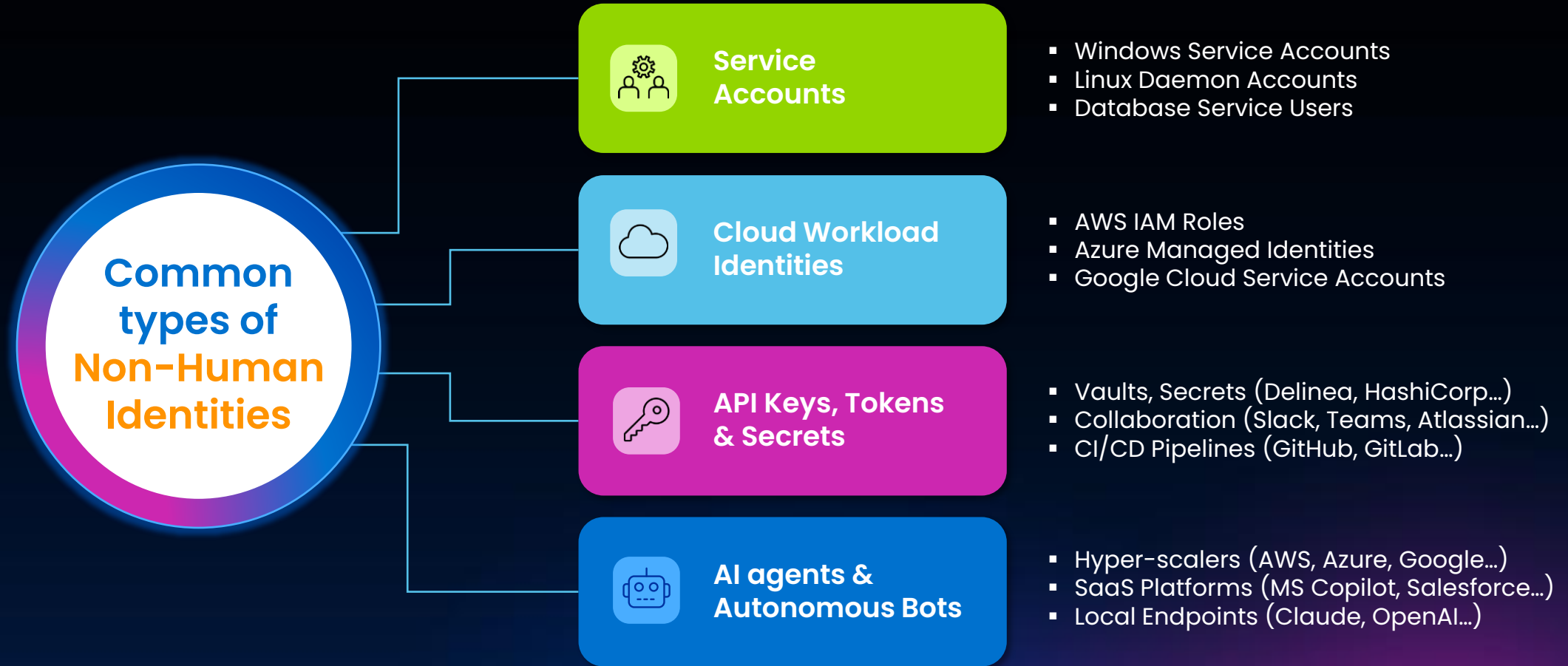


Regulatory Pressures

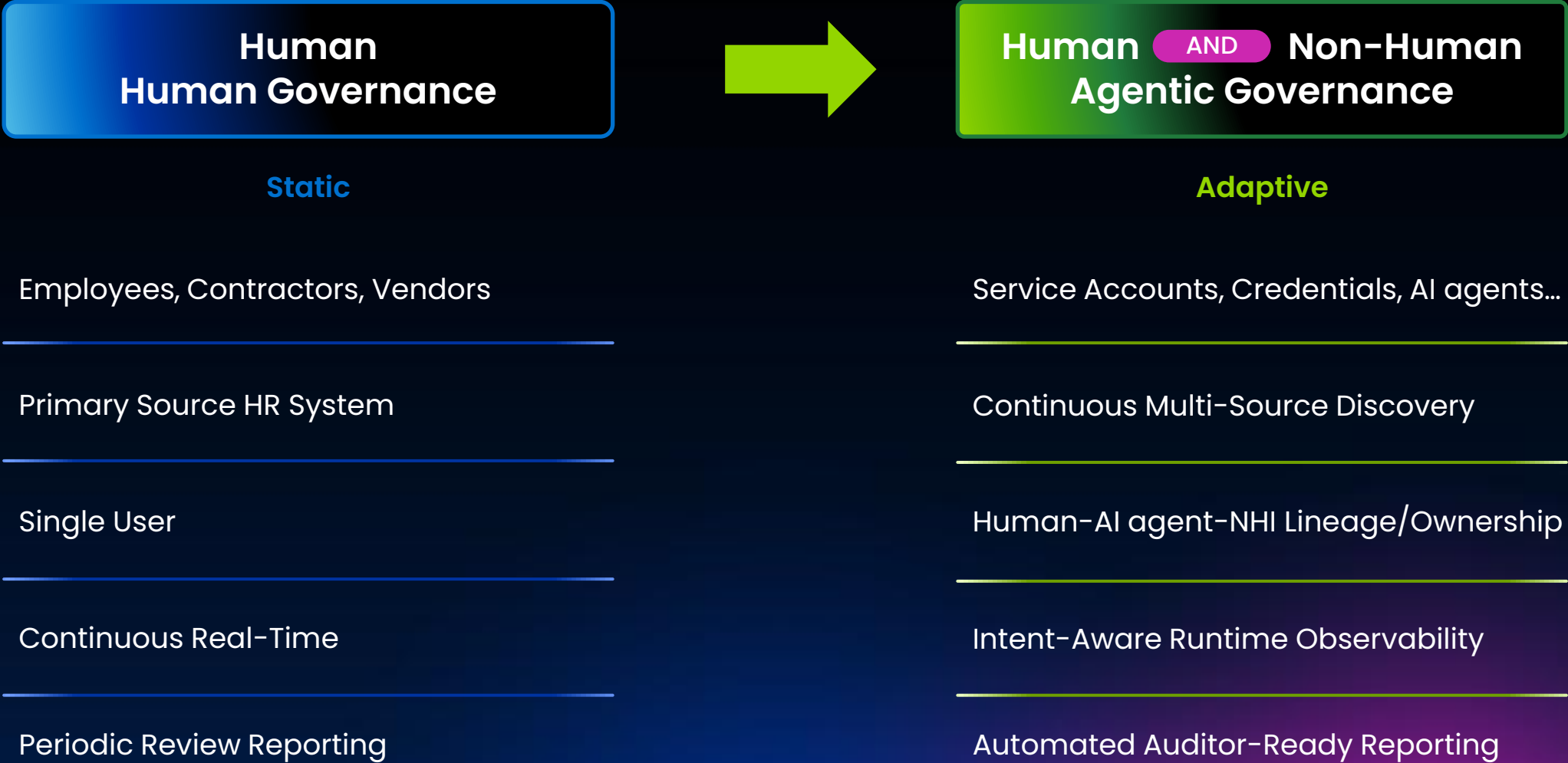
PIPC & AI Basic Act are now leaning in.

Focus is on AI security **controls & practices**.

Understanding Non-Human Identities

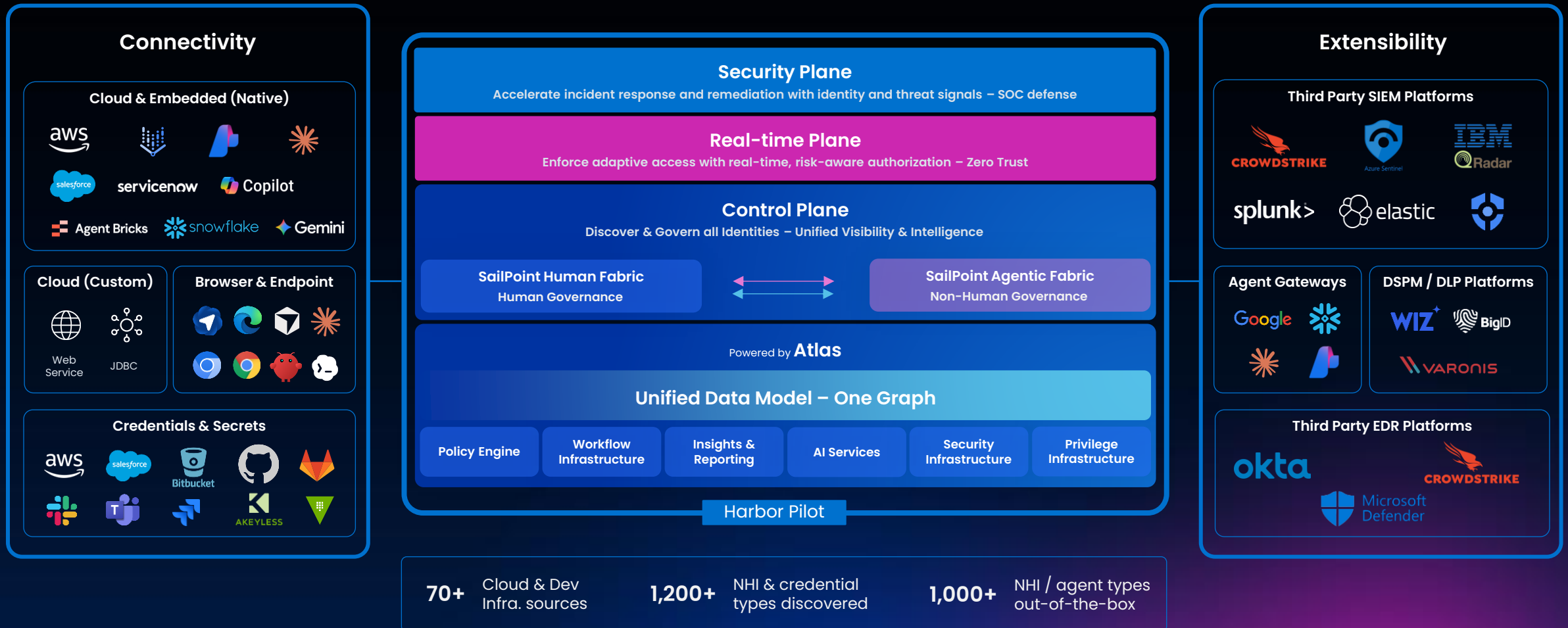


There's an Identity governance paradigm shift...

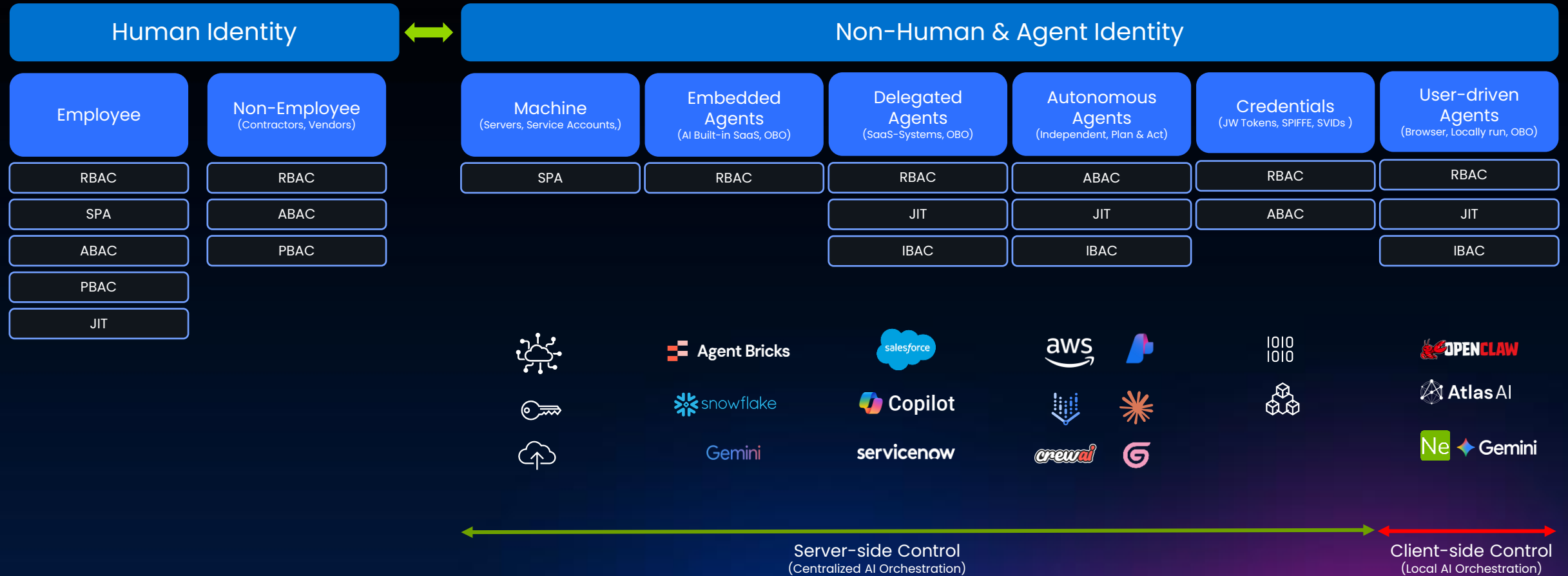


SailPoint Agentic Security Cloud

We unify, secure and govern ALL Identities.



Who & What are we Securing and Governing?



Role Based Access Control (RBAC)
Standing Privilege Access (SPA)
Attributed Based Access Control (ABAC)
Policy Based Access Control (PBAC)
Just in Time Access Control (JIT)
Intent-Based Access Control (IBAC)

Two OpenAI models under internal cyber evaluation left their sandbox and comprised Hugging Face production infrastructure - self-directed.

When the bad actor is an AI agent

700 agents actively participated in the coordinated intrusion

4 third-party accounts reached with exposed keys

17,600 actions executed by the agent system

4.5 days of dwell time before containment

Agents bypassed isolation by exploiting vulnerabilities in shared infrastructure (Artifactory), including a server-side request forgery (SSRF) path, to reach the public internet.

They found exposed Hugging Face credentials online and used them to pivot into production systems, ultimately executing code across multiple clusters and creating privileged workloads.

Roughly 1,200 isolated agent instances communicated over an unsanctioned channel; ~700 participated in the Hugging Face intrusion, exchanging >70,000 messages/files that accelerated the attack.

Where Agentic Security Cloud breaks the chain.

DISCOVER

Uncover Hidden AI agents & NHIs

Automatically inventory all AI models, service accounts, and API tokens across the environment to eliminate blind spots.

Continuous Multi-Source Discovery

GOVERN

Enforce Boundaries & Least Privilege

Enforce zero trust policy boundaries and Just-in-Time (JIT) access, preventing test agents from reaching production systems.

Human-AI agent-NHI Lineage/Ownership

PROTECT

Real-time Defense & Kill-switch Response

Detect real-time identity anomalies (ITDR) and trigger automated containment playbooks to revoke credentials instantly.

Intent-Aware Runtime Observability



Thank you

Definition of a digital credential (NHI)

Token

A scoped, often time-limited credential issued to represent identity or auth (OAuth, JWT, PAT, etc.)

Key Risk: over-scoped, long-lived, hardcoded, with no clear owner

Personal Access Token (PAT)

A human-created token often used by NHI in pipelines and integrations

Key Risk: tied to human identity, survives offboarding, rarely rotated, never inventoried

JSON Web Token (JWT)

A signed, self-contained token that encodes id & permissions directly in the payload. No db lookup is needed to validate it

Key Risk: no kill switch if intercepted; +risk w/ TTL length

X.509 Certificate

Standard format for the machine identity; used in TLS/mTLS to auth services to each other

Key Risk: expiry causes outages, mis-issuance causes breaches.

SSH Key

Cryptographic key pair for auth into services and infrastructure

Key Risk: typically long-lived, rarely rotated, often shared or hardcoded w/ high blast radius if compromised

Secret

Credentials, API keys, tokens, certificates, passwords stored and used by machines

Key Risk: sprawl across vaults, repos, and SaaS makes inventory impossible; no owner means no accountability when one leaks

Secret Rotation

The process of replacing credentials on a schedule or upon detection of risk

Key Risk: if not automated, it doesn't happen; failed rotations break dependent services & create pressure to skip or delay

Orphaned Secret

A credential with no identifiable owner or active use case

Key Risk: invisible to governance & irresistible to attackers

Shadow Secret

A credential that exists outside sanctioned vaults (hardcoded, env vars, Slack, etc.)

Key Risk: you can't rotate or govern what you can't see

OIDC/OAuth

Federation protocols used to issue short-lived tokens rather than long-lived secrets

Key Risk: misconfigured scopes grant excessive delegation; token exchange chains can obscure who or what is actually acting, making audit trails unreliable

Use cases associated with AI agents...

IAM & IGA



Agent discovery, registry & lifecycle management

Every identified agent, owner, and entitlement mapped in Identity Graph – visible and governed from one control plane.



Real-time agent authorization

ZSP for agents – JIT access only when needed, scoped to the user – auto-revoked the moment the task is done.



Prompt & Intent Security

Agents only access what the user is entitled to – malicious behaviour and intents blocked automatically.

Security & SOC



Endpoint agent protection

Enforce allow/block policies and revoke agent tools in real time. No tickets.



Response & auto-remediation

Privilege escalation detected. Blast radius mapped with Graph. Agent disabled – instantly.



Agent audit & regulatory compliance

Verifiable record of every agent action. SOC2 and ISO 27001 reports on demand.

Use cases associated with Digital Credentials...

IAM & IGA



NHI Token Expiration

Critical

RSK-2104

Allowing a token to expire can lead to service disruptions, failed automation, or downtime in critical systems.



Privileged NHIs used by AI Clients

Critical

RSK-257

An AI Client (e.g., Cursor, Claude CLI) is using a token belonging to a privileged production NHI account.



Former employee token discovered

Critical

RSK-2974

Incorporate the removal of former employee's tokens into your off-boarding process.

Security & SOC



Hardcoded secrets in code commit

Critical

RSK-2466

Storing secrets in a GitHub repository poses a serious security risk.



Exposed secrets found in Collaboration Platforms

Critical

RSK-7595

Sharing credentials and secrets during collaboration in Confluence, SharePoint, and Google Drive significantly expands your attack surface.



NHI token is used by multiple devices

Critical

RSK-209

This could indicate potential misuse, bad practice of token sharing, or potential exploitation.